SECURITY ENGINEERING RESEARCH POSTER

Non-Executing Security Analysis of AI Model Supply-Chain Artifacts

Provenance, Serialization, Impersonation, and Repository Risk Inspection

github.com/poojakira/hf-model-provenance-scanner - public, default branch main.

EVIDENCE POSTURE

Verified, scoped, reproducible

Claims are constrained to the repository evidence snapshot and stated limitations.

260	1	6	75.67%
Tests passed	Tests skipped	Additional pytest subtests passed	Statement coverage

SYSTEM VIEW

Architecture and Threat-Control Flow

Trust Boundary

Input surface
Data, models, requests, policies, or artifacts entering the tested path.

Control surface
Repository-specific validation, analysis, and fail-closed checks.

Evidence surface
Findings, metrics, tests, logs, or reproducible artifacts.

This diagram describes the tested repository path, not a universal deployment guarantee.

01 **Enumerate repository and model artifacts.** →

02 **Parse supported serialization/model formats.** ↓

04 **Reject unsafe dynamic-execution paths in the scanner itself.** ←

03 **Apply AST, pattern, symbolic, taint-style, metadata, and provenance checks.** →

05 **Emit findings and fail-loud states for incomplete or unsafe analysis.**

Research Contribution

A primarily non-executing model-artifact security scanner combining static code analysis, symbolic and taint-style inspection, binary-format parsing, provenance checks, and fail-loud handling of incomplete analysis before model loading.

Verified Evidence

EV-01 260 passed, 1 skipped, 6 subtests passed (Oct 14 2026 main CI run 38498005353).

EV-02 75.67% statement coverage; CI gate is 75%.

EV-03 Lint/format, type checking, Bandit, pip-audit, CodeQL, Trivy repository-filesystem scanning (not an image scan), unsafe-dynamic-execution rejection, and Docker build jobs succeeded.

EV-04 The committed adversarial fixture evidence remains fixture-scoped; it must not be generalized to arbitrary model repositories.

EV-05 CI coverage gate: 75%

Method and Control Path

01 **Enumerate repository and model artifacts.**

02 **Parse supported serialization/model formats.**

03 **Apply AST, pattern, symbolic, taint-style, metadata, and provenance checks.**

04 **Reject unsafe dynamic-execution paths in the scanner itself.**

05 **Emit findings and fail-loud states for incomplete or unsafe analysis.**

Limitations and Residual Risk

- Static analysis cannot prove a model is safe.
- No claim is made that neural weight backdoors are generally detected.
- Fixture-level results do not establish population-level precision or recall.
- Unsupported or incomplete parsing must remain fail-loud rather than silently clean.

Reproducibility

```
Expected evidence at the cited snapshot: 260 passed, 1 skipped, 6 subtests passed, 75.67% coverage (Oct 14 2026 main CI run 38498005353). Measured code snapshot: 09aaa224776b8de0e53315a63c260eb3229bf9ac Evidence CI run: 38498005353
```

Evidence Provenance

Claim discipline
Metrics come from the repository's verified metrics and research brief.

Scope discipline
Benchmarks are reported only at their documented fixture, dataset, or test scope.

Reproduction
PDF and PNG are generated locally from committed evidence without paid services.

Evidence-backed security engineering

README, verified metrics, tests, CI, and committed artifacts remain authoritative. Poster layout emphasizes architecture, controls, evidence, limitations, and reproduction rather than unsupported efficacy claims.

36 x 48 in
PDF + PNG parity